IF.U

小程序开发与维护交接文档

面向后续开发人员与技术维护负责人

版本 1.0 · 2026-10-20

> **接手后先完成三件事**
> 克隆并复现本地检查，理解支付与权限边界，再核对云端代码、环境配置与当前体验版。

代码基线

main / 0d4dc1349cd4

上一轮体验版：2026.10.19-mm1

配套可编辑源文档：docs/IFU-development-maintenance-handover.md

包含架构、开发流程、部署与回退、故障排查和接手清单

阅读导航

首次接手依次阅读；排障时直接查第 21 章。目录可点击跳转。

01 代码基线与接手顺序 03

02 在新机器复现本地开发 04

03 请求链路与系统组成 05

04 按需求找到修改位置 06

05 前端源文件与生成链 07

06 统一 API 与会话隔离 08

07 角色和管理权限校验 09

08 核心数据与所有权 10

09 邀请归属与人工服务流程 11

10 商品快照与订单状态 12

11 支付确认与幂等履约 13

12 认证材料与加密兼容 14

13 原生管理后台与受控写入 15

14 沙龙消息与媒体维护 16

15 性能与缓存维护规则 17

16 一次需求修改的完整做法 18

17 分层测试与验收记录 19

18 环境配置与凭据交接 20

19 云函数候选包与受控部署 21

20 客户端上传与审核发布 22

21 常见故障的定位顺序 23

22 备份回退与数据修复 24

23 后续工作与实测待办 25

24 交接资产与参考索引 26

两条交付线

云函数代码部署与小程序客户端上传分开完成。构建通过、工具上传成功、体验版已选择、审核通过和正式发布各有独立结果。

01 / 开始接手

代码基线与接手顺序

IF.U 是微信原生小程序，包含普通会员端、主理人工作台和业务运营后台。日常开发从前端页面、统一云调用和 hlApi 业务规则三层定位。

本次交接基线

项目	已确认内容
仓库与分支	git@github.com:zhaofei0923/HL_dev_cloud.git；main。
提交	0d4dc1349cd4678eab7393240ec61e5208ebda34，2026-10-19。
工作区	仍有历史文档和 Weda 扩展未提交；接手先看 git status，保留原有工作。
本机验证	2026-10-20 的 npm run check：1713 项通过、0 失败、0 跳过；这是当前工作区结果，包含本机未跟踪测试。
客户端记录	上一轮体验版 2026.10.19-mm1 已确认上传；实际选中版本、审核与正式发布状态须另行核对。

接手第一周

01 第 1 天：取得仓库与开发者工具权限，复现本地安装、构建和检查；阅读第 3 至第 11 章。

02 第 2 至 3 天：在授权范围只读核对云函数包、环境配置、商品、权限与备份，建立缺失资产清单。

03 完成一次小范围改动：补定向测试、构建生成物、真机回归，再按第 19、20 章分别处理云端与客户端交付。

> **本次文档的状态边界**
>
> 源码结构及本机检查已核对。云端当前代码、配置、备份和平台审核状态没有在本次编写时重新读取，交接时必须回读。

源码定位：README.md；package.json；specs/direct-purchase-20261019/tasks.md

02 / 开发环境

在新机器复现本地开发

微信开发者工具应导入仓库根目录。根目录配置会指定 miniprogram/ 与 cloudfunctions/，不要只导入 miniprogram 文件夹。

首次准备

01 安装 Git、Node.js/npm 和微信开发者工具；使用被授权的微信开发者身份登录。

02 从 GitHub 克隆，核对分支及提交号，再执行下面的本地命令。首次安装使用 npm ci，保留锁文件。

03 在开发者工具打开克隆根目录，核对 AppID、云环境和基础库；先用隔离样例验证页面，再使用被授权的测试账号。

本地命令

```
git clone git@github.com:zhaofei0923/HL_dev_cloud.git
cd HL_dev_cloud
node --version
npm --version
npm ci
npm run build:miniprogram
npm run check
```

版本与依赖

位置	当前约定
根开发环境	本机 Node v24.18.0、npm 11.16.0；package.json 未声明 engines，不能据此认定所有 Node 版本都兼容。
前端依赖	TypeScript 5.4.5；小程序类型依赖由 package-lock.json 锁定；基础库配置 3.16.1。
额外部署工具	CloudBase MCP/CLI、esbuild、固定 SDK、历史云包和 Node16 验证工具不由根 npm ci 补齐。

源码定位：project.config.json；package-lock.json；tsconfig.json

03 / 系统架构

请求链路与系统组成

页面通过统一服务层调用 hlApi。账号、主理人身份、管理员资格、商品金额和认证结论均由服务端决定；客户端只展示被允许的数据。



服务边界

组成	维护职责
hlApi	微信身份、会话、档案、关系、活动、支付、权益及原生后台适配。index.js 是主要路由入口，复杂业务拆在 policy/service 文件。
原生后台 bundle	native-admin-runtime.js 打包 native-admin-service 与共享管理服务，作为自包含 native-admin.bundle.js 进入 hlApi 发布包。
独立管理服务	hlAdminOperations 与 hlAdminCockpit 保留 Weda 服务；原生后台复用业务服务，但认证链不同。
支付集成函数	历史 JSAPI 的集成生成函数可能位于常规云函数目录之外，必须单独交接实际函数与云包。

两个入口协议

普通请求使用 method/path/data/token。xpay_ 云消息与内部支付通知有独立分派和认证，不能强行改成普通页面请求。

源码定位：cloudfunctions/hlApi/index.js；cloudfunctions/hlApi/native-admin-runtime.js；integrations/wechat-pay/

04 / 源码导航

按需求找到修改位置

先从页面入口找到 services 方法，再定位服务端 route 和 policy。下面的入口能覆盖大多数维护任务。

功能与源码映射

要改的内容	首先读取
登录、邀请入口	miniprogram/pages/index/；services/auth.ts；hlApi/auth-policy.js。
普通会员功能	miniprogram/pages/user/；services/member.ts；utils/ 中对应策略。
主理人五个面板	miniprogram/controllers/matchmaker/；pages/matchmaker/ 的源视图。
业务运营后台	pages/admin/portal.ts；admin-console/；services/admin-console.ts；hlAdminOperations/。
支付和权益	hlApi/membership-payment-policy.js；virtual-payment-policy.js；vip-membership-service.js。
主理人付费开通	hlApi/matchmaker-activation-policy.js、matchmaker-activation-service.js。
材料上传与核验	utils/certification-form.ts；pages/user/certification.ts；hlApi/certification-material-policy.js。
服务分配和延期	hlAdminOperations/service-intake-service.js；hlApi/member-assignment-policy.js。

定位方法

```
rg -n "目标路由或方法名" miniprogram/services cloudfunctions
rg -n "关键规则" tests
git diff --stat
```

路径中的 matchmaker 是兼容保留的代码名。产品界面统一称“主理人”；不要为了改文案批量重命名数据库字段、角色值或路由。

源码定位：README.md；miniprogram/services/member.ts；miniprogram/services/admin-console.ts

05 / 小程序开发

前端源文件与生成链

当前登记 30 个主包页面，以及 admin-console 的 workspace、detail 两个子包页面。普通会员使用四个 Tab，主理人五个面板由保留容器承载。

修改源与生成物

修改源	构建后的结果
.ts 文件	tsc 按严格模式生成同目录 .js；两者一起审查和提交。
.less 文件	原样复制为 .wxss，没有 Less 求值或嵌套编译；只写兼容 WXSS 的语法。
五面板源视图	dashboard/members/messages/salon/mine 的 WXML、LESS、JSON 组合成 workspace 视图。
controllers/matchmaker/	主理人五面板业务逻辑；旧独立页面是控制器包装，不能只改包装而遗漏工作台。

保持现有页面行为

- 普通会员四个 Tab：推荐、活动、消息、我的；导航沿用 switchTab 与选中态同步。
- 主理人工作台切换面板保留数据和滚动位置，避免改回每次跳转重建页面。容器负责转发生命周期、刷新、触底及分享。
- workspace.wxml/less/json 由脚本生成；事件名会加 workspace_{tab}_ 前缀，绑定的方法必须实际存在于控制器。

修改后的最小检查

```
npm run build:miniprogram
npm run check:generated
git diff --stat
```

源码定位：scripts/sync-matchmaker-workspace.mjs；scripts/sync-wxss.mjs；miniprogram/pages/matchmaker/workspace.ts

06 / 请求与登录

统一 API 与会话隔离

services/api.ts 是页面云调用边界。新增业务接口应同时补齐前端类型、后端参数校验、权限和失败状态，不在页面另建一套云调用协议。

services 目录中的调用示意，实际业务应定义 DTO 类型

```
import { request } from './api'

request<unknown>('/user/profile', {
  method: 'GET'
})
```

请求与会话规则

环节	接手时要保留
请求与应答	wx.cloud.callFunction 的 data 包含 path、method、data、token；应用层 code=0 才返回业务 data。云调用成功不等于业务成功。
微信登录	wx.login 的 code 交给 /auth/wx-login，可信身份来自服务端 OPENID；手机号是另外一次本人授权。
本地状态	setSession 同步 App.globalData 与本机 token/user；新增页面使用现有会话工具。
迟到的 401	仅当请求 token 与 env 仍等于当前会话时清登录，避免旧请求踢掉新账号。
页面隔离	pageSessionScope 含环境、账号和凭证指纹；同时校验 revision/generation、页面实例与卸载状态。

增加异步读取时

01 开始请求时捕获 scope 与请求代次；相同读取可复用在途 Promise。

02 返回后确认会话、查询条件及页面仍有效，再更新视图或缓存。

03 换号、失权、离页时清理私密状态；失败结果不能把旧数据标记为最新。

源码定位：miniprogram/services/api.ts；miniprogram/services/auth.ts；miniprogram/utils/page-session.ts

07 / 权限模型

角色和管理权限校验

普通用户、主理人和业务管理员分别授权。currentRole、按钮可见或本地缓存都不能替代服务端权限。

认证链不要混用

身份或入口	校验与用途
业务用户	JWT 验签后回读账号状态、合并状态与 authVersion。服务端 OPENID 才是微信身份来源。
主理人	读取有效 hl_matchmakers 记录并校验 certificationStatus=2；付费开通不意味着个人资料已认证。
原生业务管理员	/user/admin-entry 与每次动作检查 MINIPROGRAM_ADMIN_USER_IDS、账号状态及 authVersion；actor 由服务端构造。
Weda 内部管理员	CloudBase parseContext 后再次核对 ACTIVE/internalUser/administrator，不使用主理人资格授权。
历史 ADMIN 会话	/admin/login 的 ADMIN_CODE 与专用会话指纹仍有兼容接口；常规运营使用原生后台。

调整权限时覆盖这些用例

- 授权账号、普通账号、主理人账号分别验证；账号停用、合并或 authVersion 变化后，旧会话应失效。
- 默认 access 24 小时、refresh 30 天、ADMIN 2 小时；签发 refreshToken 不代表已有任意可调用的刷新接口。
- 更改 JWT_SECRET 会影响会话，且可能影响历史认证材料派生密钥；轮换前核对第 12 章的兼容要求。

源码定位：cloudfunctions/hlApi/auth-policy.js；cloudfunctions/hlApi/admin-entry-policy.js；cloudfunctions/hlApi/native-admin-service.js

08 / 数据维护

核心数据与所有权

业务数据通过受控云函数访问。先区分账号、公开档案、私密材料、归属、资金事实和权益，再讨论字段变更。

主要集合

数据域	集合与维护要点
账号和公开资料	hl_users、hl_profiles：账号状态/合并/authVersion 控制会话；公开字段经 DTO 白名单投影。
主理人与归属	hl_matchmakers、hl_members、hl_member_matchmaker_requests：有效归属具有唯一性；主理人资格与关系分离。
私密资料	hl_member_private_archives、hl_member_certifications、hl_member_identity_claims：禁止通用 CMS 直接编辑或公开枚举。
商品和支付	hl_membership_plans、hl_payment_orders：订单保留购买快照；金额为分单位整数。
三类服务权益	hl_vip_entitlements、hl_matchmaking_packages、hl_matchmaking_requests、hl_matchmaking_readiness；主理人开通另见 activationGrants。
活动和聊天	hl_salon_events、hl_registrations、hl_match_records、hl_conversations、hl_chat_messages。
锚点与审计	hl_counters、hl_admin_audit_logs：包含并发锚点、支付占位及幂等记录，不能当展示缓存清空。

> **数据修复前先查关联**
>
> 账号合并、主理人变更、订单履约、材料加密上下文相互关联。不能只替换 userId、删除旧账号或改一个 memberType 就完成迁移。

源码定位：cloudfunctions/hlApi/index.js；cloudfunctions/hlApi/member-assignment-policy.js；cloudfunctions/hlApi/vip-membership-service.js

09 / 会员业务

邀请归属与人工服务流程

免费加入、付费购买和人工服务分别推进。新增规则不得重新加入已移除的管理员审批，也不能把购买成功解释为已完成牵线。

邀请码加入

01 本人打开邀请链接或输入邀请码，查看主理人并确认；符合条件时直接建立免费会员归属，无需管理员审批。

02 已有有效主理人关系时不能被新链接静默覆盖；归属写入须推进 memberAssignmentUser_<userId> 锚点 revision。

03 免费关系不赠 VIP，不清空已有付费服务，也不授予主理人或管理员权限。

人工服务从购买到扣次

01 新订单采用 user_entitlement_v1，权益归当前账号；未绑定主理人也可购买。付款确认即开始套餐有效期。

02 后台分配负责主理人，主理人联系本人并核对服务准备；更换主理人后重新确认准备状态。

03 本人发起的牵线申请仍需负责主理人确认 serviceConfirmed，之后才可双方同意；主理人发起安排也要双方确认。正式建立关系/会话时事务扣一次，拒绝、取消或未完成不扣。

> **兼容历史订单**
>
> 缺少新合同标记的订单保留旧归属契约。不要批量补标记或用新目录覆盖旧订单价格、服务次数与原始有效期。

源码定位：cloudfunctions/hlApi/purchase-contract-policy.js；cloudfunctions/hlApi/member-assignment-policy.js；cloudfunctions/hlApi/relationship-policy.js

10 / 支付维护

商品快照与订单状态

VIP、人工牵线、主理人开通是三类独立商品。目录、平台商品与订单快照须一致，服务端决定金额，客户端不能自报价。

当前源码目录

商品代码	元 / 期限或次数
vip_week / vip_month	61.60 / 7天；198 / 30天。
vip_quarter / vip_year	398 / 90天；698 / 365天。
matchmaking_double	2980 / 付款确认后30天 / 2次。
matchmaking_month_6	6980 / 付款确认后30天 / 6次。
matchmaker_lifetime	6980 / 一次性 / 无期限，不附赠 VIP 或牵线次数。

资金与履约分别判断

状态	应如何理解
pending / confirming	资金未确认或仍在核验；查同一原订单及支付尝试。
paid + fulfilled	付款确认并已完成对应权益处理；角色开通仍须回读实际主理人权限。
paid + requires_review	已收款但履约有冲突或身份变化；进入复核，不能让用户再次购买。
closed / failed / refunded	结束、失败或退款有不同可信凭据与权益处理；不能只改前端显示。

> **两个 6980 元商品**
>
> 人工牵线1个月与主理人永久开通不是同一商品。六档套餐启停列表不包含独立主理人方案；持久化目录及支付开关决定实际可售状态。

源码定位：cloudfunctions/hlApi/vip-membership-service.js；cloudfunctions/hlApi/membership-payment-policy.js；cloudfunctions/hlApi/matchmaker-activation-policy.js

11 / 支付维护

支付确认与幂等履约

新购业务使用微信虚拟支付与苹果 IAP 支持；历史 JSAPI 订单保留原通道查询、迟到付款和售后兼容。提供方由服务端订单契约决定。

完整付款链路

01 服务端创建不可变商品快照、原订单和支付占位，获取受控收银台参数；不同虚拟支付尝试与业务订单分开记录。

02 客户端调起收银台后只启动结果查询。平台查单或可信推送核对原订单、付款人、金额、环境、交易号与应用/商户身份。

03 内部支付接口先验证 PAYMENT_CALLBACK_TOKEN；相同交易重复通知幂等，事务内写资金事实及权益。申请变化或身份冲突时保留 requires_review，小程序不得直接确认收款。

04 回读原订单、发货结果、权益账本；主理人开通再读取真实资格。通过后客户端才展示完成状态。

必须保留的边界

- 关闭收银台或用户取消不等于平台已经关单。查询全部 virtualPaymentAttempts；旧 CLOSED 结果不能关闭并发产生的新尝试。
- 不同交易号的重复成功付款进入 duplicate_payment/requires_review；不要再自动放行新付款。
- 退款凭据必须与原交易和金额相符，回收该订单权益；部分退款或异常进入复核，不能手工只标 refunded。
- activationGrants 与申请指纹防止重复开通、旧回调覆盖新审核和恢复已撤销权限；退款或撤销记录不能被清空后重放。

> **验收标准**
>
> 至少关联平台查单、服务端订单、回调/支付尝试、幂等发货、权益账本和新会话回读。仅打开收银台或客户端 success 不构成付款履约验收。

源码定位：cloudfunctions/hlApi/virtual-payment-policy.js；cloudfunctions/hlApi/matchmaker-activation-service.js；integrations/wechat-pay/hl-payment-response-verifier.js

12 / 隐私与认证

认证材料与加密兼容

五类认证为 identity、education、vehicle、property、assets。自填资料、上传成功、主理人开通和管理员核验结论分别记录。

材料生命周期

阶段	规则
选择与上传	JPEG/PNG/PDF，真实文件头与 MIME 一致；每份上限 500 KiB，即512000字节，每类型最多3份。PDF 从微信聊天文件选择。
学历编号方式	学信网验证码或留服认证编号可不上传附件；其他要求材料的方式需1至3份。敏感编号独立加密。
云端暂存	AES-256-GCM 加密后才上传 .enc；staging 有效24小时，过期后不能读/提交，后续上传触发清理，并非定时物理删除。
提交与核验	事务核对本人、类型、材料状态及 applicationId，再绑定申请；上传不自动通过，拒绝新申请不必撤销旧的有效结论。
公开摘要	只投影允许的认证标签；资产分类同意与档位公开两个 Boolean 由本人分别设置；资产认证按规则有6个月有效期。

密钥与访问要求

- 优先 MEMBER_CERTIFICATION_ENCRYPTION_KEY，保留 jwt-derived-v1 历史来源；管理服务仅接收所需专用密钥与 MEMBER_CERTIFICATION_JWT_DERIVED_KEY。
- AAD 绑定用途、版本、keySource、用户、类型和材料 ID。不得改归属字段后直接搬密文；轮换先验证旧材料解密并制定迁移方案。
- 本人读取校验归属、绑定状态与有效期；管理员额外核对当前申请版本和 applicationId。日志、工单、缓存不记录证件正文、base64、fileID 或临时链接。

源码定位：cloudfunctions/hlApi/certification-material-policy.js；cloudfunctions/hlAdminOperations/material-service.js；miniprogram/pages/user/certification.ts

13 / 业务管理开发

原生管理后台与受控写入

主线后台是“我的 → 管理后台”的原生页面。六个模块加经营总览复用共享管理服务，不把历史 Weda 预览页视为同一套页面。

管理服务入口

模块	主要职责与边界
主理人 / 认证	matchmakers / certifications：处理待审主理人和个人认证；付费已开通不重复审批，个人认证仍需核验。
salons / plans	历史活动审核/取消和固定套餐启停；不改既有订单快照或任意改价。
orders	查询付款、履约和退款，只读；主理人订单当前按全部产品类型再搜索订单号。
services / cockpit	分配主理人、说明原因后延期1至30天、经营统计；延期不修改原始购买金额和次数。

新增写动作时必须沿用

01 READS/WRITES/MATERIALS 动作白名单和每次服务端授权；不能接受客户端自报管理员 actor。

02 先 operations.prepare 获取 requestId，带详情中的 expectedVersion；确认弹窗展示对象、动作与影响。

03 事务再次核对账号、当前申请/归属和版本，再写入审计；action、参数指纹、requestId 必须一致。

04 结果未确认沿用原 requestId 和原参数查询/重试；版本冲突先刷新并重新确认，不能另造 ID 绕过。

> **外层传输协议**
>
> Weda transport envelope 先鉴权，再投影 action/args/requestId；外层可忽略无关 transport 字段，内层 args 仍严格按动作校验。

源码定位：cloudfunctions/hlApi/native-admin-service.js；cloudfunctions/hlAdminOperations/mutation-service.js；cloudfunctions/hlAdminOperations/request-envelope.js

14 / 其他业务

沙龙消息与媒体维护

沙龙、报名、关系与会话都有服务端归属校验。界面成功后的下一步应与业务状态一致，避免把资料保存或报名等同于付费完成。

常见修改入口

功能	继续开发时的约束
主理人沙龙	符合条件的主理人可直接发布为待举办，无需管理员逐次审批；历史待审记录仍保留处理入口。
会员报名	保存资料后返回活动，还须点击报名；报名成功不等于活动费用已经支付。活动邀请不能顺便更改主理人归属。
聊天与语音	普通和主理人聊天共用 utils/chat-page.ts、chat-voice.ts；分页、权限和生命周期集中修改，避免两份逻辑分叉。
普通图片	utils/local-image.ts 负责选择、裁剪、上传、临时链接与部分失败清理；私密路径不能改为公共目录。
认证材料	独立走认证加密上传，不复用普通头像/公开照片的上传与下载流程。

回归场景

- 沙龙发布：正常主理人、停用账号、无主理人账号；过去时间、人数、费用与取消状态校验。
- 聊天：非会话成员拒绝、首次80条、历史翻页、afterId 增量、换号、切后台、离页后录音/音频停止。
- 图片与 PDF：用户取消、授权拒绝、超限、网络中断、失败后重试和离页清理；不为修复前端无反应绕过服务端文件校验。

源码定位：cloudfunctions/hlApi/salon-policy.js；miniprogram/utils/chat-page.ts；miniprogram/utils/local-image.ts

15 / 响应速度

性能与缓存维护规则

先测请求数、耗时、返回体积和页面更新量，再优化。延长缓存时间不能替代失效策略、权限校验或会话隔离。

当前源码中的优化

位置	行为
推荐列表	快照 TTL 45秒；按会话和完整查询隔离、合并在途读取、公开字段白名单、分页去重。
主理人面板	快照 TTL 30秒；dashboard/mine 共享读取，修改后失效快照和旧在途结果。
消息和资料	消息刷新 TTL 10秒，个人资料30秒；切号、失权或业务变更时不沿用旧缓存。
聊天和心跳	聊天每批80条，回到页面拉 afterId 增量；在线心跳前台60秒一次，后台停止。
包与组件	原生后台拆子包；lazyCodeLoading=requiredComponents；本仓库媒体预算严格小于200 KiB。

下一次性能优化怎么做

01 分别记录冷启动、已登录返回、切面板、刷新及弱网；区分云函数冷启动、数据库、网络和 setData 时间。

02 优先复用/并行独立读取，缩小 DTO 和 setData；分页与缓存键要保留查询、账号、环境及权限边界。

03 核对写入后的失效、旧请求隔离、错误时清敏感状态；用定向测试和相同设备前后对比验收。

> **预算含义**
>
> 200 KiB 是本仓库的媒体检查预算，不是微信平台对完整小程序包大小的规则。

源码定位：miniprogram/utils/showcase-cache.ts；miniprogram/utils/matchmaker-page-cache.ts；scripts/check-media-budget.mjs

16 / 继续开发

一次需求修改的完整做法

以“增加会员资料中的普通非敏感展示字段”为例。先确定谁能填写、谁能看到以及是否进入推荐，再开始写代码。

从需求到可审查改动

01 写下请求/响应、默认值、长度或枚举、本人编辑权限及公开范围；确认是否必须收集，敏感字段走独立方案。

02 定位 services/member.ts 和后端 profile route/policy；服务端白名单、类型验证、存储与公开 DTO 同步修改。

03 修改普通会员表单；若主理人也可维护，要明确本人专属同意字段仍不可代填。

04 需要进入缓存时审查 PUBLIC_FIELDS；修改成功后使相关列表/详情缓存失效，处理换号和离页后的迟到结果。

05 补正常、缺省、超长/非法值、越权、旧数据兼容和公开投影测试，再构建 TS/JS 与 LESS/WXSS。

06 检查差异，跑定向与完整检查，真机验证。涉及云逻辑时先按云部署流程交付，再上传对应客户端版本。

开发者日常闭环

```
npm run build:miniprogram
node --test tests/api-session-isolation.test.js
npm run check
git diff --check
git diff --stat
```

> **交付说明需要包含**
>
> 问题触发方式、改动后行为、影响的接口/角色、验证结果、迁移与回退影响，以及仍需补齐的实测。

源码定位：miniprogram/services/member.ts；cloudfunctions/hlApi/showcase-policy.js；tests/api-session-isolation.test.js

17 / 质量验证

分层测试与验收记录

本地自动化、目标运行时、开发者工具、手机实测和平台状态分别验收。测试数量会随提交和本机外部资产变化，应记录实际命令与结果。

变化类型与验证重点

改动	至少验证
页面与模板	生成物、类型、导航、生命周期、普通/主理人账号，真机弱网与回到页面。
API与权限	越权拒绝、停用/合并、authVersion、旧 token、当前数据归属、迟到请求隔离。
支付与权益	金额/快照、重复通知、并发尝试、退款、旧单兼容、角色变化；实付另做受控闭环。
后台动作	prepare/确认、expectedVersion、幂等原操作重试、审计、敏感内容清理。
云端包	独立 SDK 打包输入、目标 Node 加载与授权回归、完整云包回读、配置保护及权限冒烟。

检查入口

```
npm run check:generated
npm run check:media
npm run check:admin-workflows
node --test tests/api-session-isolation.test.js
node --test tests/chat-pagination.test.js
npm run check
```

新机器若提示缺少历史云包、esbuild、固定 SDK 或 Node16 校验工具，明确登记 skip 与原因并补齐所需验证。不得删除失败用例、降低断言或把 skip 记为部署通过。

建议每次记录 commit、Node/npm、命令与退出码、失败/跳过项、模拟器与手机/微信版本、云包摘要和验证时间。当前仓库未跟踪 CI 流水线；本地通过不能写成 GitHub CI 通过。

源码定位：package.json；tests/native-admin-deployment.test.js；scripts/verify-admin-workflows.mjs

18 / 配置维护

环境配置与凭据交接

客户端仅放公开标识，密钥保存在服务端受控配置。源码指向 AppID wx7e5c0f4d07d2f0f8、环境 cloud1-d2gza7q9c8d69c721；迁移时必须重新确认目标。

变量按用途分组

分组	变量名与用途
会话与管理	JWT_SECRET；MINIPROGRAM_ADMIN_USER_IDS；ADMIN_CODE。签名、原生后台名单和历史管理员入口分别管理。
材料加密	MEMBER_CERTIFICATION_ENCRYPTION_KEY；MEMBER_CERTIFICATION_JWT_DERIVED_KEY，保留历史密文兼容。
虚拟支付	VPAY_OFFER_ID、VPAY_ENV、VPAY_APP_KEY、VPAY_SANDBOX_APP_KEY、WX_APP_SECRET、PAYMENT_CALLBACK_TOKEN。
开放开关	PAYMENT_INTEGRATION_READY、MATCHMAKING_PAYMENT_READY、VIP_MEMBERSHIP_CATALOG_READY；配置不等于业务已实测。
历史支付	PAYMENT_FUNCTION_NAME、PAYMENT_CREATE_PATH、PAYMENT_QUERY_PATH，保留旧单与售后路径。
开发及初始化	NODE_ENV、ALLOW_LOCAL_JWT、ALLOW_MOCK_WECHAT_LOGIN、JWT_DEV_SECRET、SEED_DATA、DEMO_MEMBERS、AUTO_CREATE_COLLECTIONS。

配置变更注意

- VPAY_ENV 的0为正式、1为沙箱，与体验版/正式版客户端发行渠道不同。生产不得启用模拟身份或本地 JWT 回退。
- SEED_DATA 需显式 true 才播种；DEMO_MEMBERS、AUTO_CREATE_COLLECTIONS 的关闭语义是显式 false，不能把缺配置理解为已关闭。
- 环境迁移同时检查客户端 cloud.ts、后端 TCB_ENV/CLOUDBASE_ENV_ID 及 native-admin-runtime.js 的固定环境；凭据值单独受控交接。

源码定位：miniprogram/config/cloud.ts；cloudfunctions/hlApi/auth-policy.js；cloudfunctions/hlApi/virtual-payment-policy.js

19 / 云端发布

云函数候选包与受控部署

本地 hlApi 目录不等于完整云端发布包。发布需要现网基线、依赖与配置保护、自包含后台 bundle、目标运行时和部署后回读。

每次云代码发布

01 明确目标 EnvId、函数、Runtime/Handler、改动范围；下载当前完整云包，登记平台摘要、所有文件清单与配置摘要，保存回滚 ZIP。

02 在当前基线上合入限定补丁。原生后台或共享管理服务变化时重建 native-admin.bundle.js，固定 SDK 打入自包含 CJS；其他补丁保留并核对原 bundle 摘要。

03 核对 bundle 输入与 SDK、metafile、候选 ZIP 摘要及差异；在实际目标 Node 合同下加载和运行授权回归。历史准备器目标为 Node16.13。

04 确认候选和恢复路径后发出一次代码更新。网络中断先核对实际状态与摘要，结果不明不盲目重发。

05 整包下载回读，核对源码、依赖、属性、运行时与配置保护；health 后再做授权/拒绝和关键业务只读冒烟。

历史脚本的真实参数

脚本（scripts/）	位置参数
prepare-native-admin-deployment.mjs	无参数，绑定历史基线和原主机工具路径。
deploy-native-admin.mjs	inspect / deploy / verify。
deploy-release-performance.mjs	prepare / deploy / verify，没有 inspect。
deploy-paid-matchmaker.mjs	inspect / deploy / verify，没有 prepare。

> **新机器先迁移工具链**
>
> 以上是脚本合同索引，不是可直接重放的发布命令。历史 output、SDK/esbuild/Node16 绝对路径和批准基线均需核对适配，不能删除保护断言或用空依赖包绕过。

源码定位：scripts/prepare-native-admin-deployment.mjs；scripts/deploy-paid-matchmaker.mjs；cloudfunctions/hlApi/native-admin-runtime.js

20 / 版本交付

客户端上传与审核发布

GitHub 推送、云函数部署、小程序上传、设体验版、提交审核和正式发布是不同结果。每一项记录自己的版本和证据。

客户端版本交付顺序

01 先完成源码及生成物检查。若改后端契约，确认云端对应候选已部署并回读，再使用开发者工具导入仓库根目录。

02 预览完整小程序，分别用普通账号、主理人和业务管理员验证关键入口。iPhone 与安卓的支付表现分别记录。

03 填写唯一版本号与面向审核的变更说明，上传；遇本机确认由当前操作人员确认，再查询原上传任务结果。

04 在公众平台确认开发版本已存在并将目标版本设为体验版；完全退出旧小程序，重新扫码确认版本和行为。

05 审核资料与隐私声明须匹配实际能力，提供审核测试路径和正确订单中心路径 pages/user/orders；提交后记录平台结果。

06 审核通过后按负责人安排发布；再检查普通用户入口、云端错误与核心业务，保留前一版本与回退方案。

每次交付台账

字段	如何记录
源码	分支、commit、已验证的 staged tree 及剩余改动。
云端	EnvId、函数、候选/回读摘要、配置保护、回退包与验证时间。
客户端	上传版本/时间、体验版选中状态、真机系统/微信版本及二维码来源。
平台	审核提交、审核结果、正式发布，各自状态和时间；未完成就保持待完成。

源码定位：project.config.json；miniprogram/pages/user/orders.ts；README.md

21 / 故障处理

常见故障的定位顺序

先记录北京时间、环境、函数、客户端版本、脱敏业务编号、订单或记录 ID、requestId、错误码和最短复现步骤。日志只保留定位必需字段。

现象与下一步

现象	定位顺序
仍看到旧文案	核对扫码入口和体验版版本，完全退出重扫；再查客户端生成物和云端摘要，不先删权限条件。
401 / 40100 / 40102	确认 token 与环境、当前账号 status/mergedIntoUserId/authVersion；重新登录，不能放宽鉴权绕过。
40360 / 40361	查业务账号与 MINIPROGRAM_ADMIN_USER_IDS、有效状态；主理人付款不会获得管理员权限。
42250 / 42260	对照请求协议、request-envelope 与 action/args 参数合同；外层 transport 字段与内层业务字段分开。
40940 / 40960	记录或申请已变；刷新并核对最新版本。原操作超时则保留原 requestId 和参数查询结果。
已付但未到账	同一原订单 → 平台查单/支付尝试 → 回调/发货 → fulfillmentStatus → 权益账本/当前角色。禁止要求盲目重买。
认证上传/预览失败	文件选择/授权 → 大小/MIME → 材料归属和版本 → 存储与密钥兼容；不输出证件正文。
后台慢或暂不可用	按 native_admin_request_failed 和 requestId 查日志，再查 bundle、SDK/运行时、冷启动、数据库及返回体积。

> **部署中断**
>
> 代码更新请求一旦发出，先 verify 实际摘要与状态，不能因工具超时自动再 deploy；health 可响应后仍须核对业务与配置。

源码定位：cloudfunctions/hlApi/index.js；integrations/wechat-pay/hl-payment-safe-log.js；cloudfunctions/hlAdminOperations/mutation-service.js

22 / 恢复维护

备份回退与数据修复

代码回退不会撤销已经发生的付款、退款、会员归属或权益变动。恢复方案必须分别覆盖代码、配置、数据库、云文件和密钥。

需要保管的恢复资产

资产	登记与验收
云代码包	当前完整 ZIP、候选和回滚包、平台摘要、文件清单、运行时及源码 commit。
配置与密钥	配置摘要用于比对，不能代替恢复值；单独受控保存密钥及材料 keySource 兼容关系。
数据库	实际备份策略、可恢复时间点、关联集合和恢复权限；必须确认实际存在及可恢复。
云文件	认证密文与引用元数据相配；不可只恢复文件或只恢复文档。

处理需要修复的数据

01 只读定位并导出最小受限范围的变更前快照；核对关联、唯一性、当前版本和金额/材料上下文。

02 写专用 dry-run，列目标数量、前置指纹、拟修改字段与不变量；经范围确认后用事务或条件写入执行。

03 回读审计、权限、账本和关联计数，再用真实业务路径核对结果，保留脚本版本、前后快照和恢复办法。

> **不得用改状态模拟恢复**
>
> 不删除订单、不手改 paid/fulfilled/refunded、不清空 activationGrants 或计数器、不覆盖历史权益快照。若代码旧版本不理解新契约，优先评估向前修复。

源码定位：cloudfunctions/hlApi/member-assignment-policy.js；cloudfunctions/hlApi/matchmaker-activation-service.js；scripts/deploy-paid-matchmaker.mjs

23 / 接手后的优先级

后续工作与实测待办

先补运行资产与关键实测，再做工程改进。以下按交接记录区分已知结果与仍需取得的验收证据。

优先级与完成条件

优先级	工作及完成条件
P0 支付实测	用户已报告 iPhone 能调起6980元苹果收银台；实际付费后主理人自动开通、幂等/重复回调与退款处理仍需独立受控闭环。
P0 云与恢复	读取当前函数/完整依赖包、平台商品与环境，核对备份和恢复点。不能把历史部署文件视作今天现网事实。
P0 发布状态	核对当前体验版、审核和正式发布。mm1 上传记录不能替代当前平台选中或审核结果。
P1 真机专项	认证图片/PDF上传、审核预览、邀请码直入、沙龙直接发布和后台写动作逐项用授权账号验证。
P1 工具链迁移	参数化本机绝对路径、固定基线和候选输入；保留保护检查，补新机部署准备与目标运行时验证。
P2 工程改进	统一 Node/npm 版本约定与 CI；继续拆分 hlApi/index.js，并补性能基准、日志指标和恢复演练。

每项待办如何关闭

- 登记负责人与测试范围、账号角色、环境、版本、步骤和成功/失败标准；包含异常与取消路径。
- 真实付款须事先确定单账号、单订单、原单无冲突和试付安排；核对平台到权益闭环后记录结果，不能只收一张支付截图。
- 将结果更新到需求/任务与交接文档；模拟、只读、真机、实付和平台状态分别标注。

源码定位：specs/direct-purchase-20261019/tasks.md；specs/native-admin-miniprogram/tasks.md；README.md

24 / 正式交接

交接资产与参考索引

交接以接手者能独立构建、定位问题和完成一次受控发布为完成标准。账号和密钥值另走受控渠道，本页只登记应取得的资产。

双方逐项确认

交接项	完成依据
仓库与工作区	仓库/分支权限、基线 commit、未提交文件负责人、当前需求和未解决问题。
平台与业务账号	开发者工具/体验/审核权限，CloudBase 只读/发布权限，普通/主理人/管理员测试账号映射。
支付与密钥	虚拟商品/正式沙箱、集成函数/回调/售后负责人；JWT、材料、支付密钥保管和轮换恢复路径。
构建与恢复	本机工具链位置、固定 SDK、目标 Node、bundle 输入、最新云包/回滚包、数据库和云文件恢复点。
验收与后续	本地检查、真机清单、实付专项、平台审核/上线状态和下一次发布计划。

建议阅读次序

- README.md → package.json/project.config.json → miniprogram/services/ → hlApi 入口与对应 policy/service → tests/。
- specs/direct-purchase-20261019/ 与 specs/native-admin-miniprogram/ 保存当前需求/设计；新需求同步修改任务和验收记录。
- docs/member-showcase-certification.md 详述材料契约；部分历史管理员 API/部署说明保留当时流程，以当前原生后台、源码与测试为准。
- docs/cloudbase-cms-operations.md、weda-admin/README.md 用于兼容运营视图；普通 CMS 不编辑支付、权益或私密认证。

提交前只暂存本次验证范围，不使用全量添加

```
git status --short
git diff --check
git diff --cached --stat
git diff --cached --check
git write-tree
```

源码定位：README.md；specs/；docs/member-showcase-certification.md；docs/cloudbase-cms-operations.md